SRD / SISTEMA DE REGISTRO DIGITAL

Manual técnico

Arquitectura, operación, diagnóstico y mantenimiento

Juan Sebastián González Horta
Servicio Nacional de Aprendizaje (SENA)
Centro de la Industria, la Empresa y los Servicios (CIES)
Programa: Análisis y Desarrollo de Software

Versión 1.1 · revisión al 19 de octubre de 2026 (historial 09/10 preservado)

Propósito

Referencia para la persona que mantiene y extiende SRD. Describe la estructura física del repositorio, sus fronteras de datos y los controles reales del incremento 0.1.

Alcance documental

Documento elaborado para el incremento de desarrollo y demostración local de SRD. Las funciones no implementadas o todavía sin aceptación se distinguen expresamente de las verificadas; no constituye una certificación de producción.

CONTENIDO

01 1. Sistema y alcance
02 2. Topología desplegada
03 3. Código y fronteras
04 4. Modelo de seguridad
05 5. Integridad y concurrencia
06 6. Auditoría y patrón outbox
07 7. Planificadores y antivirus
08 8. Mantenimiento de esquemas y contratos
09 9. Compilación, pruebas y empaquetado
10 10. Observabilidad y diagnóstico
11 11. Respaldos, retención y secretos
12 12. Restricciones pendientes
13 Fuentes de referencia
14 13. Guía de responsabilidades de los dominios
15 14. Contratos, control de cambios y compatibilidad
16 15. Seguridad aplicada y operaciones negativas
17 16. Auditoría: operación y recuperación controlada
18 17. Respaldos, restauración y continuidad
19 18. ClamAV, imágenes y seguridad de carga
20 19. Observabilidad y mantenimiento semanal
21 20. Límites y ruta a puesta en producción
22 21. Reglas de dominio y casos de regresión
23 22. Pruebas mínimas antes de cerrar una incidencia
24 23. Referencia de archivos del repositorio

1. Sistema y alcance

SRD es una plataforma multi-tenant para Juntas de Acción Comunal. Permite gestionar cuentas, configuración, personas, agenda, notificaciones, tesorería informativa, inventario, carpetas y archivos privados, chat y auditoría. Los clientes web, Windows y Android usan una misma entrada de API. Su estado es un incremento en desarrollo; la funcionalidad no sustituye los procedimientos jurídicos, contables ni archivísticos de las JAC.

2. Topología desplegada

Topología local contrastada con compose.yaml del 19/10/2026: Nginx/React, API Gateway Laravel, diez dominios (identity, configuration, records, audit, files, calendar, notifications, treasury, inventory y chat), MySQL 8.4 con esquemas separados por dominio, nueve planificadores y auxiliares Mailpit, Reverb y ClamAV/actualizador. Las funciones de exportación residen en dominios existentes; no existe un microservicio Reportes desplegado. Las bases no se crean por cada junta: las operaciones filtran la organización identificada en el contexto firmado.

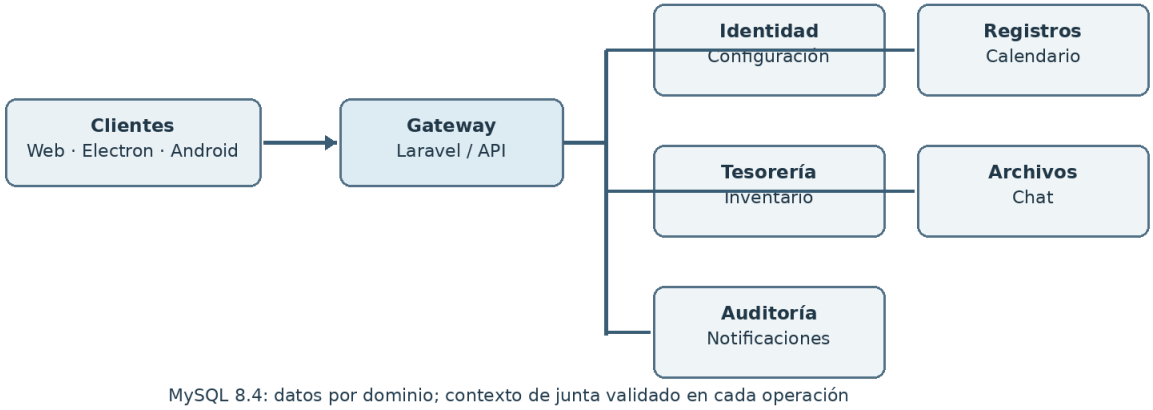


Figura 1. Clientes, Gateway y diez dominios implementados.

Servicio	Responsabilidad	Base lógica
gateway	Entrada HTTP, sesión, CSRF, enrutamiento, contexto interno firmado	srd_gateway
identity	Identidad, cuentas, roles, membresías y MFA	srd_identity
configuration	Juntas, parámetros, delegaciones y accesos rápidos	srd_configuration
records	Fichas, filtros, estados y exportación de personas	srd_records
audit	Recepción, consulta y exportación de eventos	srd_audit
files	Fotografías, carpetas, documentos y escaneo	srd_files
calendar	Agenda, participantes y recordatorios	srd_calendar
notifications	Bandeja y preferencias de avisos	srd_notifications
treasury	Cuenta y movimientos informativos COP	srd_treasury
inventory	Bienes, existencias y movimientos	srd_inventory

Servicio	Responsabilidad	Base lógica
chat	Conversaciones, texto, entregas y tiempo real	srd_chat

El alcance del diseño incluye un servicio de reportes especializados, pero no existe como dominio implementado en este ZIP. Los PDF y Excel presentes se generan actualmente desde dominios particulares o desde la web.

3. Código y fronteras

Ruta de lectura: apps/web/src/ para interfaz TypeScript; apps/desktop/ para Electron; apps/mobile/ para React Native; services/<dominio>/ para controladores, aplicación, persistencia, migraciones y pruebas; apps/api-gateway/ para sesión/contexto; docker/ y compose.yaml para la topología; scripts/ para operaciones. La denominación de las carpetas prevalece frente a diagramas históricos. Un cambio de contrato debe acompañarse de adaptación de cliente y regresión del rol afectado.

Ruta	Contenido y contrato de cambio
apps/web	React 19, TypeScript, Vite, i18n parcial y exportaciones
apps/desktop	Electron Windows x64, cliente que carga el servidor web
apps/mobile	React Native nativo; compilación debug y aceptación parcial
apps/mobile-expo	Variante para exposición física mediante Expo Go SDK 57
services/<dominio>	Aplicación Laravel, rutas, políticas y migraciones propias
packages/php	Contrato de autenticación interna, permisos, correlación y outbox
contracts	OpenAPI por servicio y esquema audit-event.v1.schema.json
docker y compose.yaml	Imágenes, volúmenes, redes, sondas y servicios auxiliares
scripts	Inicialización, pruebas, respaldo, empaquetado y demostración
docs	ADR, estado, trazabilidad, validación y pendientes

4. Modelo de seguridad

La web usa sesión y controles CSRF; Gateway valida membresía, términos y rol, y firma un contexto acotado de usuario/junta/permisos. El servicio de dominio revalida la autorización, el recurso y organization_id antes de leer o escribir. React oculta operaciones que el rol no puede ejecutar, pero la denegación confiable es la del servidor (403/404 según el contrato). No reutilizar secretos internos entre una instalación de prueba y un VPS público.

Los objetos privados respetan autorización de descarga, cuotas, tipos y análisis ClamAV. Si la antigüedad de las firmas supera el umbral operativo, Files responde 503 y rechaza la carga. El 19/10/2026 ese bloqueo seguía presente: no deshabilitar el escaneo para obtener una prueba verde. Reanudar únicamente cuando se valide la actualización de firmas.

El cliente no envía como autoridad su propio rol o UUID de junta. El Gateway obtiene el contexto de una sesión válida y lo firma al invocar servicios internos. Cada dominio vuelve a comprobar rol, membresía, junta y pertenencia del recurso; el aislamiento se aplica en filtros y consultas. El control de acceso de interfaz evita mostrar acciones, pero nunca reemplaza la autorización del servidor.

Rol	Operaciones representativas
SA · superadministrador	Administración de plataforma y juntas; operaciones permitidas de su junta activa
AD · administrador	Miembros, configuración y gestión operativa de la junta
RE · registrador	Crear/editar personas, notas internas autorizadas
TE · tesorero	Consulta y movimientos de Tesorería e Inventario
AU · auditor	Consulta y exportación de auditoría de la junta
CO · consultor	Consulta autorizada de personas y otros recursos permitidos

Carpetas privadas admiten lectura delegada explícitamente por rol o membresía; de forma inicial está deshabilitada. El Gateway protege sesiones mediante cookies y CSRF; la verificación adicional de correo se observa en Mailpit únicamente en el entorno local.

5. Integridad y concurrencia

Las versiones y controles de concurrencia ocasionan 409 cuando otro cambio ganó la carrera; debe leerse el dato actualizado antes de reintentar. Las mutaciones financieras conservan asientos y reversos, con controles de idempotencia para operaciones repetidas. Cuando hay timeout después de enviar una escritura, su resultado es incierto: consultar el recurso por identificador y estado antes de crear otro registro.

Las bases MySQL pertenecen a dominios, no a juntas individuales. Los identificadores de recursos entre dominios se transmiten por API; no se deben implementar JOIN entre las bases propietarias. En Tesorería el saldo y la numeración se actualizan con bloqueo transaccional, sin editar asientos confirmados: se usan reversos. Inventario registra movimientos históricos por bien. Las carpetas emplean versión para detectar edición concurrente y rechazan mover una carpeta dentro de sus descendientes.

6. Auditoría y patrón outbox

El evento mínimo se guarda junto con la mutación en la transacción del servicio de origen; schedulers reintentan la entrega y Audit deduplica por UUID. Se conservan metadatos, no el contenido de notas, mensajes ni secretos. Supervisar pendientes/agotados por emisor y validar migraciones: un contenedor healthy no implica que las tablas de dominio estén listas.

Los servicios emisores guardan el hecho auditable en su outbox dentro de la misma transacción de negocio. El publicador srd:outbox lee el lote, envía el evento con identificador estable y espera accepted:true de Auditoría. El receptor inserta sin duplicar identificador. Los fallos incrementan attempts, con hasta cuatro intentos automáticos y retrasos intermedios. El estado distingue publicados, pendientes, listos, diferidos y agotados.

```
docker compose exec records php artisan srd:outbox-status
docker compose exec records-scheduler php artisan srd:outbox
```

```
docker compose exec audit php artisan migrate:status
```

Un cero en exhausted indica que no hay filas agotadas en ese emisor cuando se consultó; no demuestra que todos los componentes externos estén disponibles. Nunca reiniciar intentos o borrar eventos sin respaldos, análisis del motivo y autorización.

7. Planificadores y antivirus

La recuperación del 19/10 tras la falta de respuesta de Docker Desktop devolvió HTTP 200 en la web y 23 servicios saludables en esa fotografía. Ese conteo no sustituye la comprobación individual del scheduler requerido para invitaciones, auditoría y notificaciones. El motor de firmas debe ser reciente; 503 por caducidad es una condición de bloqueo, no una carga exitosa.

Hay nueve planificadores de Laravel para tareas periódicas. Sus sondas verifican marcadores de ciclo y de publicación de auditoría. Archivos procesa limpieza de fotos y documentos; Chat procesa entregas. ClamAV corre como servicio interno, con escáner TCP en antivirus:3310; otro contenedor ejecuta FreshClam cada seis horas sobre un volumen de firmas compartido. El servicio Archivos consulta /var/lib/clamav/srd-update-ok para validar actualización.

```
docker compose ps files-scheduler chat-scheduler antivirus
docker compose logs --tail=60 antivirus-updater
docker compose exec antivirus clamdscan --version
```

8. Mantenimiento de esquemas y contratos

Las migraciones viven en services/<dominio>/database/migrations y se aplican solo a la base de ese servicio. Una evolución de endpoint debe revisar contratos/*.openapi.json, pruebas PHP, integración Gateway y consumidor React o móvil. Un cambio en evento auditable debe respetar audit-event.v1.schema.json y mantener idempotencia.

```
docker compose exec files php artisan migrate:status
docker compose exec files php artisan migrate --force
node tools/contracts.mjs
```

El comando de migración es aditivo cuando existen migraciones pendientes; debe ejecutarse con respaldo y control de cambios. No borrar tablas ni modificar volúmenes para resolver un error de arranque.

9. Compilación, pruebas y empaquetado

Ejecutar en PowerShell, desde la raíz: .\scripts\Test-Browser.ps1 -Compose -Spec web-empty-states.spec.mjs. Para varios archivos: .\scripts\Test-Browser.ps1 -Compose -Specs @('service-status.spec.mjs','person-base-filters.spec.mjs'). Archivar evidencia de .local/browser-runs junto con la imagen concreta probada y limpiar únicamente fixtures de prueba.

Al 19/10/2026, 33 de 140 archivos distintos aprobaron sobre una imagen web; no son 33 casos de 140 ni evidencia de regresión completa. Tres archivos con expectativas antiguas se actualizaron y aprobaron individualmente. La matriz por rol, capturas de todos los estados y suite integral continúan abiertas.

```
./scripts/Test.ps1
npm ci --prefix apps/web
```

```
npm run build --prefix apps/web
./scripts/Test-FilesApi.ps1
./scripts/Test-OutboxConcurrency.ps1
./scripts/Package.ps1
```

Test.ps1 instala dependencias Composer por servicio salvo que se use -SkipInstall, ejecuta suites PHPUnit y compila React. Package.ps1 genera un ZIP de fuentes excluyendo secretos, datos de ejecución, binarios y node_modules. Los informes de pruebas realizadas se conservan en docs/VALIDACION.md.

10. Observabilidad y diagnóstico

Síntoma	Primer punto de investigación
La web no carga	docker compose ps; logs web gateway
Un módulo responde 500	logs del dominio; migrate:status; variables resueltas
MFA no llega	Mailpit en localhost:8025; logs identity/notifications
Evento agotado	srd:outbox-status en emisor y estado de audit
Scheduler unhealthy	docker inspect .State.Health; logs y marcadores
ClamAV stale	antivirus-updater logs; fecha de srd-update-ok y clamdscan --version
Acceso a datos de otra junta	revisar contexto firmado, consultas filtradas y pruebas de autorización

11. Respaldos, retención y secretos

Backup-Local.ps1 genera el respaldo cifrado local; Test-BackupRestore.ps1 -VerifyOnly autentica la copia y Test-BackupRestore.ps1 prueba restauración solo en un MySQL aislado. Custodiar por separado .local/backups/recovery-key.bin y el archivo cifrado. Una restauración productiva debe reaplicar supresiones posteriores al respaldo y conciliar consistencia interdominio: el ensayo local no garantiza RTO ni RPO.

El respaldo local usa scripts/Backup-Local.ps1, cifra el contenido con AES-256-GCM e incluye objetos privados. La clave de recuperación se almacena localmente y no debe incorporarse al repositorio. El simulacro de restauración se ejecuta contra un MySQL temporal aislado, sin sobrescribir las bases activas. Las políticas de retención, réplica externa y recuperación ante desastre no están cerradas para producción.

12. Restricciones pendientes

El entorno Compose usa PHP de desarrollo y puertos de loopback; producción requiere servidor PHP adecuado, HTTPS/WSS, cookies Secure, SMTP externo autorizado, TURN probado entre redes, respaldo externo y pruebas de carga. Android y Windows carecen de distribución firmada aceptada; el servicio Reportes separado es diseño pendiente.

- Falta aceptar integralmente 56 RF y verificar capacidad bajo concurrencia representativa.
- Falta dominio especializado de reportes, adjuntos y voz de Chat, llamadas y privacidad integral.
- El cliente Windows es un prototipo sin instalador firmado; Android no dispone de release final.

- HTTPS/WSS, monitoreo continuo y protección operativa requieren preparación adicional antes de uso público.

Fuentes de referencia

SRD/README.md; docs/ARQUITECTURA.md, PERMISOS.md, OUTBOX.md, RESPALDOS.md, ESTADO.md, VALIDACION.md, MOVIL.md y ESCRITORIO.md; compose.yaml; packages/php/console.php; contracts/*.openapi.json. Edición de código del 09/10/2026.

13. Guía de responsabilidades de los dominios

Un mismo servidor MySQL no implica una única base compartida. Cada dominio tiene su esquema, sus migraciones y sus reglas. Antes de cambiar un contrato conviene revisar su OpenAPI, sus políticas y el consumidor web correspondiente.

Gateway y sesión

El Gateway expone las rutas públicas, valida la sesión, controla CSRF y traslada un contexto firmado a los servicios internos. La autenticación no termina en la interfaz: cada dominio vuelve a autorizar la operación.

Puntos de revisión: Comprobar el acceso a /api/health; identificar rutas públicas; verificar que un contexto ajeno sea rechazado por el servicio de destino.

```
docker compose exec gateway php artisan migrate:status
docker compose logs --tail=25 gateway
```

Identidad y membresías

Identidad gestiona cuentas de plataforma, membresías por junta, invitaciones, términos, inicio de sesión y código adicional. La revocación de permisos exige invalidar sesiones afectadas y cerrar conexiones asociadas.

Puntos de revisión: Revisar invitaciones agotadas, sesiones revocadas, correo en Mailpit y validación de pertenencia a la junta.

```
docker compose exec identity php artisan migrate:status
docker compose logs --tail=25 identity
```

Configuración de junta

Configuración almacena parámetros por organización, permisos de delegación y componentes que cambian por junta, incluidos accesos rápidos, filtros visibles y catálogos. Cada cambio debe estar versionado cuando corresponda.

Puntos de revisión: Verificar que cambios en una junta no alteren la configuración de otra y que las versiones anteriores den conflicto 409.

```
docker compose exec configuration php artisan migrate:status
docker compose logs --tail=25 configuration
```

Registros de personas

Registros mantiene fichas, documentos, estados pendiente/completado, notas internas y campos configurables. Las búsquedas y los exportes consultan la junta activa y respetan permisos de cada rol.

Puntos de revisión: Revisar identificación única, filtros combinados, concurrencia de fichas y permisos de exportación.

```
docker compose exec records php artisan migrate:status
docker compose logs --tail=25 records
```

Auditoría

Recibe hechos mínimos enviados por otros dominios. La deduplicación por identificador impide duplicar registros si un publicador reintenta una entrega confirmada. El esquema audit_events es imprescindible.

Puntos de revisión: Comprobar migraciones, recepción de eventos y que los emisores agotados no se oculten tras un HTTP healthy.

```
docker compose exec audit php artisan migrate:status
docker compose logs --tail=25 audit
```

Archivos

Administra fotos privadas, documentos DOCX/XLSX y jerarquías de carpetas. Aplica permisos, cuotas, normalización de imagen y controles ClamAV. Las carpetas tienen versiones para evitar sobrescribir movimientos simultáneos.

Puntos de revisión: Revisar migraciones de srd_files, escáner antivirus, marcador de firmas, permisos de descarga y limpieza de archivos.

```
docker compose exec files php artisan migrate:status
docker compose logs --tail=25 files
```

Calendario

Maneja eventos con zona horaria de Colombia, participantes, delegación de edición y recordatorios configurables. El servicio prepara trabajos durables para Notificaciones.

Puntos de revisión: Comprobar estados temporales, deduplicación de recordatorios y conflictos al editar versiones antiguas.

```
docker compose exec calendar php artisan migrate:status
docker compose logs --tail=25 calendar
```

Notificaciones

Proporciona bandeja privada, preferencias y entregas internas idempotentes de Chat y Calendario. Las notificaciones no son mensajes enviados necesariamente al correo externo.

Puntos de revisión: Validar recepción, preferencias del destinatario, supresión del distintivo en No molestar y aislamiento por junta.

```
docker compose exec notifications php artisan migrate:status
```

```
docker compose logs --tail=25 notifications
```

Tesorería

Registra ingresos y egresos informativos en COP, comprobantes consecutivos y reversos. Los movimientos se confirman transaccionalmente y no equivalen a operaciones bancarias.

Puntos de revisión: Verificar integridad de centavos, saldo no negativo, reverso único, autorización SA/AD/TE e historial.

```
docker compose exec treasury php artisan migrate:status
docker compose logs --tail=25 treasury
```

Inventario

Mantiene bienes muebles e inmuebles, existencia, movimientos, baja histórica y fotografías. Los reportes de inventario corresponden a este dominio, no a un microservicio de reportes especializado.

Puntos de revisión: Comprobar movimientos sin pérdida de historia, códigos de la junta, filtros y descarga autorizada.

```
docker compose exec inventory php artisan migrate:status
docker compose logs --tail=25 inventory
```

Chat

Persiste conversaciones directas, mensajes de texto, estados de entrega y lecturas. Contiene tareas de entrega y WebSockets privados; notificaciones de mensajes no reproducen su contenido.

Puntos de revisión: Verificar membresía de conversación, suspensión de cuentas, paginación de 25 y reintentos de entrega.

```
docker compose exec chat php artisan migrate:status
docker compose logs --tail=25 chat
```

14. Contratos, control de cambios y compatibilidad

14.1 Ciclo de cambio de una operación

Identificar el dueño del caso de uso y revisar su archivo contracts/<dominio>.openapi.json. Definir la autorización en el servicio y no solo en React. Cambiar la migración con el principio aditivo cuando sea posible. Actualizar las pruebas PHP y las integraciones que consuman el contrato. Confirmar también que los eventos mínimos enviados a Auditoría no incluyan datos privados innecesarios.

Las rutas de una versión existente no deben romper a un cliente Android o Windows sin plan de compatibilidad. Las propiedades opcionales deben tener comportamiento definido al faltar, como sucede con textos ES/EN y recordatorios históricos.

14.2 Revisión antes de fusionar cambios

1. Identificar requisito o incidencia y el servicio propietario.

2. Actualizar contrato OpenAPI, validaciones y migración antes de cambiar el formulario.
3. Añadir prueba de permiso negativo, datos de otra junta y versión desactualizada cuando aplique.
4. Ejecutar tests del servicio y compilación de la web sin tocar datos reales.
5. Anotar en docs/VALIDACION.md comando, fecha, resultado, evidencia y límites.
6. Revisar el mecanismo de reversión; no depender de migrate:fresh para solucionar conflictos.

14.3 Cambios entre dominios

Ningún servicio debe acceder directamente mediante JOIN a tablas privadas de otro dominio. Si un caso requiere conocer identidad, junta o estado de otro recurso, usar el contrato interno disponible y contemplar fallos temporales. El Gateway es entrada para clientes, no propietario de cada regla de negocio.

14.4 Migraciones seguras

Inspeccionar migrate:status en el servicio implicado y respaldar cuando ya existan datos. Ejecutar migrate --force únicamente con el destino confirmado. Si el script Up.ps1 encontró esquemas incompletos, los dominios pueden parecer healthy aunque las funciones fallen: este caso se verificó en Auditoría, Archivos y Chat el 9 de octubre.

15. Seguridad aplicada y operaciones negativas

15.1 Matriz de roles

Los roles del proyecto son SA, AD, RE, TE, AU y CO. No todos los permisos nacen exclusivamente del rol: algunas lecturas de carpeta y ciertas ediciones de calendario pueden ser delegadas por la administración de la junta. La pertenencia debe seguir vigente en el instante de la solicitud.

El contexto firmado debe contener la identidad autenticada de forma que el servicio pueda verificar actor, junta y permiso. Los casos de rechazo deben formar parte de cada suite: consultar un identificador de otra junta, modificar un registro ajeno, descargar un objeto privado sin permiso y reutilizar una sesión revocada.

Referencia operativa: Permisos

SA: superadministrador. AD: administrador. RE: registrador. TE: tesorero. AU: auditor. CO: consultor.

La lectura delegada de Carpetas empieza deshabilitada en cada junta. SA/AD pueden conceder o revocar RE/TE/AU/CO mediante Configuración → Acceso a Carpeta; la concesión incluye navegación, listado, vista previa disponible y descarga privada, pero ninguna escritura. El backend verifica el rol y la configuración vigente en cada petición. El cambio se guarda con versión y deja evento mínimo folder.access_updated. La delegación por usuario y la de escritura siguen pendientes.

La tabla conserva el alcance de los módulos, aunque algunos siguen parciales. Tesorería e Inventario ya aplican sus permisos en endpoints propios; la exportación general sigue pendiente. Las delegaciones comienzan deshabilitadas. Están implementadas por separado la edición de filtros visibles y la de campos adicionales de personas: SA/AD pueden habilitar cada una para RE/TE/AU/CO dentro de su junta y revocarla; los delegados no pueden otorgar permisos. Las

delegaciones de cargos y otros módulos siguen pendientes. La administración de cuentas no puede conceder un rol global desde un administrador de junta.

Srd\Access implementa la política utilizada por los servicios existentes. React filtra acciones; el backend decide siempre. Las consultas usan organization_id derivado del contexto firmado y los recursos de otra junta responden 404. Usuarios sin nota no reciben ese campo en detalle, lista ni indicadores. Los roles descriptivos de personas no participan en la autorización.

Fuente de comprobación: docs/PERMISOS.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

15.2 CSRF, sesión y MFA

El código de segundo factor se valida tras la contraseña y la aceptación vigente de términos. El correo local se observa en Mailpit 8025 y no demuestra entrega SMTP real. Cambios de junta, suspensión o revocación de membresía exigen invalidar accesos y comprobar autorización en los dominios; jamás crear cuenta automáticamente por registrar una persona.

En acceso web las cookies de sesión no deben reemplazarse por tokens persistentes disponibles en JavaScript. Las acciones con cambios requieren comprobación CSRF; iniciar sesión, cambiar de junta y suspender cuentas deben renovar o revocar el estado correspondiente. En el equipo de exposición, el correo adicional se consulta únicamente en Mailpit.

15.3 Archivos privados

Una URL conocida no autoriza una descarga. Cada solicitud de archivo debe comprobar usuario, junta, pertenencia y permiso actuales, y la capa de almacenamiento no debe exponer el volumen en la web. El escáner antimalware y la fecha de actualización son controles distintos: no basta con que el puerto 3310 conteste.

Los documentos privados declarados son DOCX y XLSX hasta 20 MiB en el incremento. Otros tipos no deben presentarse como garantizados. La validación EICAR de extremo a extremo requiere un caso específico, separado del arranque exitoso de ClamAV.

Referencia operativa: Archivos privados

Este documento describe el procesamiento de imágenes en services/files/app, utilizado por el servicio Archivos ya desplegado. Las fichas web guardadas admiten las tres fotos mediante el gateway autenticado. La integración, cuota y limpieza se describen en ALMACENAMIENTO-FOTOS.md.

ImageGate recibe bytes y un nombre, valida extensión contra MIME real, un máximo de 5 MiB y dimensiones de hasta 20 millones de píxeles. Las entradas aceptadas son JPEG, PNG y WebP. El límite adicional de píxeles protege la memoria del decodificador y deberá revisarse con pruebas de carga antes del piloto.

Escribe el original en cuarentena con un identificador aleatorio, sin usar el nombre del usuario como ruta. ClamdScanner envía el contenido al antivirus mediante INSTREAM y solo admite una confirmación limpia exacta. Un rechazo, respuesta desconocida, conexión incompleta o timeout impiden obtener una imagen aprobada. El protocolo se implementó según la documentación oficial de ClamD.

Después del primer análisis, se lee la orientación EXIF de los JPEG y GD aplica el giro o reflejo correspondiente a los valores 1–8. Solo se consulta ese metadato después de que el original supere el antivirus. Luego se genera un PNG, descartando metadatos y contenido adicional del original.

Las dimensiones devueltas corresponden a la imagen ya orientada. Esa imagen también debe superar el límite de tamaño y un segundo análisis antes de devolverse al consumidor. El resultado incluye bytes, MIME, dimensiones, tamaño y SHA-256; no contiene una URL pública. Se retira la cuarentena tanto al completar como al fallar.

Fuente de comprobación: docs/ARCHIVOS-PRIVADOS.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

16. Auditoría: operación y recuperación controlada

16.1 Diagnosticar eventos agotados

1. Consultar el emisor con php artisan srd:outbox-status y anotar published, pending, due, deferred y exhausted.
2. Comprobar la migración del servicio Audit y existencia de la tabla audit_events.
3. Verificar conectividad interna y la clave de autenticación entre servicios sin imprimir el secreto.
4. Leer logs recientes del emisor, Audit y su planificador; clasificar error persistente o transitorio.
5. Respaldar las bases afectadas antes de alterar filas outbox.
6. Reprocesar solo los eventos cuya causa se haya corregido y comprobar su publicación, sin borrar registros.

Referencia operativa: Outbox

Los cambios de identidad, configuración y registros guardan su evento de auditoría en la misma transacción que el cambio de negocio. srd:outbox intenta entregar hasta 100 eventos vencidos por ejecución, ordenados por próxima fecha, fecha del evento e identificador.

Cada intento bloquea la fila y vuelve a comprobar que no esté publicada, agotada ni en espera. Esta comprobación se hace después de adquirir el bloqueo porque otra ejecución puede haber cambiado el evento desde que se seleccionó el lote. El bloqueo de MySQL es la protección compartida entre el planificador y ejecuciones manuales; withoutOverlapping es una protección adicional del planificador.

Solo la respuesta de auditoría con accepted: true confirma la entrega. El mensaje conserva siempre el mismo identificador, y auditoría lo deduplica. Se envían únicamente los campos del evento, sin contadores ni fechas internas de reintento.

attempts cuenta fallos de entrega. Hay hasta cuatro intentos automáticos con esperas de 1, 5 y 15 minutos entre fallos. Después del cuarto fallo el evento queda retenido y no se vuelve a enviar automáticamente. No se borra ni se reinicia su contador desde la consulta de estado.

En Auditoría → Entrega de auditoría, SA, AD y AU pueden consultar los contadores de su junta y hasta 20 eventos agotados por servicio. La página consulta identidad, configuración y registros por separado; si una consulta falla muestra su error. No permite reenviar ni modificar eventos. Las otras juntas quedan excluidas incluso para SA en esta vista.

La salida JSON distingue published, pending, due, deferred y exhausted. Pendientes incluye tanto los disponibles como los que esperan y los agotados. Es una consulta de contadores, sin datos de personas ni modificaciones.

Fuente de comprobación: docs/OUTBOX.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

16.2 Evidencia del incidente del 9 de octubre

Se aplicó la migración de audit, se respaldaron bases y se restablecieron intentos agotados tras corregir su causa. Los resultados posteriores fueron 15 eventos de Identidad, ocho de Registros, cuatro de Calendario, tres de Tesorería y tres de Inventario publicados, total 33. Después de migrar Archivos y Chat, ambos planificadores pasaron de unhealthy a healthy.

Esta evidencia verifica una recuperación puntual, no un tiempo máximo contractual de procesamiento ni tolerancia ante caídas prolongadas.

17. Respaldos, restauración y continuidad

Referencia operativa: Respaldos

La primera orden crea una copia nueva. La segunda autentica la copia más reciente. La tercera la importa en un MySQL temporal aislado, comprueba tablas y referencias y retira el contenedor y el archivo descifrado. Puedes seleccionar otra copia con -Backup 'nombre.srdbackup', siempre dentro de .local/backups.

Las copias nuevas incluyen once bases: srd_gateway, srd_identity, srd_configuration, srd_records, srd_audit, srd_files, srd_calendar, srd_notifications, srd_treasury, srd_inventory y srd_chat, junto con el .env raíz y los objetos del volumen privado. El simulacro admite también las copias anteriores sin Calendario, Notificaciones, Tesorería, Inventario o Chat cuando faltan sus claves de aplicación.

El formato de contenido 2 indica private_objects_included: true. Conserva los objetos PNG de photos, tanto de personas como de bienes de Inventario, incluidos los pendientes de retirar y los archivos sin referencia que cumplan el formato del almacén. No incluye cuarentena ni otros futuros tipos de archivo. El exportador rechaza enlaces, nombres inesperados, imágenes mayores de 5 MiB, objetos registrados ausentes o alterados y más de 100.000 imágenes. El archivo JSON acompañante solo describe la copia: al verificar y restaurar se lee el formato desde el contenido autenticado, nunca desde ese JSON.

La copia detiene los contenedores activos de web, gateway, los diez dominios y sus planificadores; conserva MySQL, Mailpit y el antivirus. La aplicación queda temporalmente inaccesible. Exporta los objetos desde un contenedor de Archivos de una sola ejecución y ejecuta mysqldump --single-transaction mientras los escritores están detenidos. No ejecutar migraciones, otros procesos que escriban a las bases ni cambios manuales en el volumen durante esta ventana.

Se validan los identificadores y el proyecto de los contenedores, y al finalizar se arrancan solamente los que estaban activos, incluso si falla la copia. Los que ya estaban detenidos permanecen así. .backup.lock impide dos copias simultáneas; .paused-UUID.json conserva los identificadores de la pausa dentro del directorio privado. Una terminación forzada puede dejar el bloqueo o servicios detenidos: revisar esos archivos y el estado de Docker antes de recuperar manualmente con Up.ps1 -SkipBuild y retirar el bloqueo de esa ejecución. El script no elimina automáticamente bloqueos antiguos ni modifica ajustes globales de Docker.

El contenido se cifra mientras se recibe, sin crear archivos SQL o imágenes sin cifrar en el equipo durante la copia. El contenedor lee el volumen original privado. El formato exterior usa AES-256-GCM, nonce aleatorio de 12 bytes, etiqueta de autenticación de 16 bytes y cabecera versionada

autenticada. El .env, el índice de fotos, sus bytes y el SQL están dentro del contenido cifrado. La verificación se basa en la etiqueta autenticada, no solo en el checksum.

La clave aleatoria de 32 bytes se guarda una sola vez en .local/backups/recovery-key.bin. Las ejecuciones siguientes la conservan. Sin esa clave no se puede descifrar la copia. En Windows se restringe el directorio de respaldos al usuario actual y SYSTEM; esos permisos se aplican únicamente dentro de SRD. El paquete de fuentes excluye .local, por lo que no incluye respaldos, claves ni datos.

El archivo se autentica completamente antes de entregar SQL a MySQL. Una clave incorrecta, truncamiento o alteración impide la importación. El temporal descifrado permanece en el directorio restringido y se elimina al terminar; no se promete borrado físico seguro del disco.

Se usa la imagen MySQL 8.4 fijada en compose.yaml, que debe estar disponible localmente. El contenedor tiene nombre y etiqueta aleatorios propios, --network none, ningún puerto publicado, límite de 768 MiB y una CPU. No monta carpetas del equipo ni volúmenes de SRD. Su almacenamiento temporal pertenece exclusivamente a ese contenedor. Se espera hasta diez minutos al servidor final mediante TCP de loopback, evitando confundirlo con el servidor de inicialización que solo abre un socket.

El simulacro importa únicamente en ese contenedor, ejecuta CHECK TABLE, cuenta tablas y filas por base y comprueba todas las claves foráneas declaradas, incluidas las compuestas. Para contenido 2 restaura cada imagen bajo /tmp/srd-photo-restore, comprueba SHA-256 de los archivos escritos, tamaño y hash contra los metadatos de fotos vigentes, presencia de objetos pendientes de retirar, conciliación de cuotas y ausencia de fotos vinculadas a marcas terminales de personas eliminadas. Los objetos sin referencia se cuentan sin eliminarlos automáticamente. La lectura del índice rechaza rutas relativas, duplicados y truncamientos.

Fuente de comprobación: docs/RESPALDOS.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

```
./scripts/Backup-Local.ps1
./scripts/Test-BackupRestore.ps1 -VerifyOnly
./scripts/Test-BackupRestore.ps1
```

17.1 Política de integridad

La prueba de restauración proporcionada importa en un contenedor temporal aislado. Nunca ejecutar el SQL de un backup sobre el MySQL operativo para comprobar que existe. La clave recovery-key.bin no va dentro de repositorios, entregables ni correos. La programación, retención y copia externa deben establecerse antes de producción.

18. ClamAV, imágenes y seguridad de carga

18.1 Topología comprobada

El servicio antivirus aloja clamd y expone el puerto TCP únicamente en la red interna. antivirus-updater ejecuta FreshClam sobre el volumen antivirus_signatures compartido. Archivos ve dicho volumen de solo lectura y consulta srd-update-ok; el script de actualización se monta desde docker/update-signatures.sh.

Clamd puede estar healthy aun cuando las firmas sean antiguas; el actualizador no tiene healthcheck propio, de modo que sus logs y el marcador forman parte de la revisión.

```
docker compose ps antivirus antivirus-updater
docker compose logs --tail=40 antivirus-updater
docker compose exec antivirus clamdscan --version
docker compose exec files sh -c 'ls -l /var/lib/clamav/srd-update-ok'
```

18.2 Problema de saltos de línea en Windows

En la sesión verificada, un script SH tenía saltos CRLF y fallaba con illegal option - en la línea set -eu. Se realizó copia .bak, conversión a LF en UTF-8 sin BOM y recreación exclusiva del contenedor updater. FreshClam descargó daily.cld versión 28148 y la prueba de base de firmas terminó satisfactoriamente.

La prevención apropiada es fijar LF en .gitattributes y validar los scripts del directorio docker al empaquetar. La seguridad de subida exige además una prueba de archivo limpio y del marcador EICAR antes de cerrar la aceptación.

19. Observabilidad y mantenimiento semanal

Frecuencia sugerida	Comprobación	Registro
Al iniciar	docker compose ps, /api/health, estado de servicios	Fecha, estado y servicio
Cada sesión de trabajo	Outbox por emisor, vencimiento de firmas, Mailpit	Pendientes y anomalías
Ante cambios	migrate:status y pruebas dirigidas	Migración, prueba y resultado
Antes de actualización	Backup-Local y VerifyOnly	Copia autenticada y custodio
Antes de exposición	Semilla ficticia, navegación web y móvil	Recorrido y capturas sin datos privados

19.1 Atención de incidentes

Registrar qué dejó de funcionar, cuándo, alcance por junta y comandos utilizados. Separar caída de contenedor de error de esquema, error de permiso y retraso de eventos. Nunca tratar un 200 de salud como evidencia de toda la funcionalidad; es un indicador de proceso, no de negocio.

20. Límites y ruta a puesta en producción

El incremento está validado en desarrollo local. Antes de disponibilizarlo en Internet hacen falta TLS válido, copias remotas, monitoreo, pruebas de carga, evaluación del aislamiento multi-junta y aceptación integral de los requisitos. La variante Android Expo Go no es un APK final; la versión Windows todavía exige completar distribución y firma. El dominio de reportes especializados permanece pendiente según la matriz de requisitos.

21. Reglas de dominio y casos de regresión

Las reglas que siguen provienen de la documentación de implementación del paquete SRD. Su propósito es orientar la prueba de cambios futuros: registrar la regla no significa que todos sus casos de aceptación de negocio estén cerrados.

21.1 Eventos, participantes y recordatorios

Referencia operativa: Calendario

Los eventos nuevos y editados desde la web guardan title/title_en y, cuando se usan, location/location_en y description/description_en. Cada junta redacta ambas versiones; no hay traducción automática. El formulario exige título ES/EN y pares completos para lugar y descripción. Las vistas, invitaciones, búsqueda y detalle eligen la versión del idioma persistente del usuario. La API mantiene opcionales los campos EN para clientes existentes; eventos históricos sin ellos siguen visibles con el texto original y requieren que la junta complete la traducción al editarlos desde la web. Los trabajos de entrega y los avisos guardan también title_en; un aviso histórico sin inglés conserva su título original. La migración aditiva se aplicó en MySQL y Chromium confirmó alta bilingüe, idioma persistente y una invitación real entregada por el planificador con ambos títulos.

Al crear o editar un evento, Recordatorios para participantes permite elegir 24 horas antes, 1 hora antes, ambas o ninguna. Los detalles de Calendario y Búsqueda de la junta muestran la selección guardada; la búsqueda conserva consulta sin edición. Invitaciones y cancelaciones siguen llegando aunque no se elija ninguna anticipación. La preferencia personal de recordatorios del destinatario sigue pudiendo suprimir la entrega; los horarios de silencio conservan los avisos y ocultan solo el distintivo.

La API admite los booleanos opcionales remind_24h y remind_1h. En un alta, cada campo omitido vale true; en una edición, cada campo omitido conserva su valor anterior, incluso si es false. Las opciones comparten la versión del evento y los mismos permisos de edición, incluidos roles delegados vigentes. La migración aditiva conserva ambas activadas en eventos existentes. Cambiar una selección retira los trabajos pendientes anteriores y prepara solo las anticipaciones elegidas; no borra avisos ya recibidos ni repite uno confirmado para el mismo inicio. Si cambia el inicio, el aviso de la nueva fecha tiene una clave independiente. Aceptar una invitación y conciliar eventos futuros respetan las opciones guardadas. Antes de entregar se comprueba nuevamente que la anticipación siga activada.

El calendario tiene un servicio Laravel y una base MySQL propios (srd_calendar). El gateway expone eventos de la junta activa y la configuración de permisos. Todas las lecturas y escrituras exigen sesión validada; solo el gateway puede solicitar esas operaciones internas. Los cambios se guardan junto con un evento mínimo en el outbox, que el planificador entrega a Auditoría. La web ofrece vistas de mes, semana y agenda, detalle y formularios de creación y edición.

SA y AD pueden crear, editar y cancelar eventos. Pueden delegar la edición por rol a RE, TE, AU o CO para su junta, y revocarla con efecto inmediato; los delegados no administran la delegación. Todos los roles con membresía activa pueden consultar eventos de su propia junta. Las operaciones de edición y cancelación exigen la versión vigente; una versión anterior devuelve 409. Cancelar es terminal.

Fuente de comprobación: docs/CALENDARIO.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

21.2 Tesorería: histórico e idempotencia

Referencia operativa: Tesoreria

El incremento implementa la parte informativa de RF-027, RF-028 y RF-029. Superadministrador (SA), administrador (AD) y tesorero (TE) pueden abrir una cuenta para su junta, consultar saldo e

historial, registrar ingresos y egresos y corregir ingresos o egresos con un reverso. Ninguna operación mueve dinero real, se conecta a bancos o procesa pagos.

En Tesorería, registra primero la apertura de la junta, incluso con importe cero. Después registra cada ingreso o egreso con importe COP positivo, fecha efectiva no futura, concepto y una referencia de soporte opcional. Un egreso que supera el saldo disponible se rechaza. El historial muestra comprobantes numerados, responsable, importe y saldo tras cada asiento. La fecha efectiva sirve para filtrar y ordenar; el saldo tras asiento corresponde al orden en que se confirmó, identificado por el número de comprobante. El saldo actual comprende todos los asientos, aunque se filtre el historial.

Buscar en la junta también permite encontrar asientos por texto del concepto o por número de comprobante completo, según permisos. El filtro q de GET /api/v1/treasury admite hasta 120 caracteres y puede combinarse con fechas y página; el saldo y los acumulados siempre reflejan todos los asientos de la junta. Ver BUSQUEDA.md.

El historial de Tesorería tiene los filtros Desde, Hasta y Concepto o comprobante. Exportar Excel descarga todos los asientos que cumplen esos filtros, aunque haya varias páginas, hasta un máximo de 2000. La API GET /api/v1/treasury/export exige permiso treasury.export de SA/AD/TE y devuelve 422 si el resultado supera el límite; no entrega un archivo incompleto. La hoja muestra importe y saldo tras el asiento en COP con dos decimales y el signo en columna aparte. Ese saldo corresponde al momento de confirmación del comprobante, no a un saldo recalculado según las fechas filtradas. Las celdas son texto, incluso los conceptos que parecen fórmulas. El servidor genera el archivo en memoria y no guarda una copia.

Exportar PDF descarga el historial filtrado en A4, con encabezado de junta, fecha de Colombia, paginación y un resumen por asiento. Cada asiento empieza en una página nueva; conserva los doce campos del Excel, incluidos concepto, referencia de soporte y vínculo al asiento revertido. El saldo tras asiento es el valor histórico al confirmar, no un saldo recalculado con los filtros ni necesariamente el saldo actual. GET /api/v1/treasury/export-pdf comparte consulta, orden, permisos y límite de 2000 con Excel. El navegador genera el PDF con una biblioteca local, sin servicios externos ni copia persistente en el servidor. Ambas exportaciones registran treasury.export con junta y actor, sin conceptos, referencias, importes ni nombre de archivo; indica entrega de datos y no acredita el guardado final.

Fuente de comprobación: docs/TESORERIA.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

21.3 Inventario: movimientos y filtros

Referencia operativa: Inventario

Exportar historial PDF comparte los filtros aplicados, permisos, nombre confirmado y máximo de 2000 movimientos de Excel. Descarga un documento A4 generado en el navegador con bibliotecas locales, sin servicios externos. Incluye las mismas once columnas, encabezado de la junta, fecha de Colombia y numeración de páginas. Cada movimiento inicia en una página nueva; el motivo se presenta por separado para permitir continuación si es extenso. Las fechas del movimiento siguen en UTC y las existencias anterior/posterior son históricas, no el saldo actual ni un recálculo con filtros. Un historial vacío produce un documento que informa que no hay coincidencias.

GET /api/v1/assets/{id}/movements/export-pdf entrega los datos autorizados para generar el documento, no un PDF persistente del servidor. Comparte el bloqueo del bien y el evento mínimo

inventory.export con Excel; ese evento confirma entrega de datos, no guardado del archivo. Por defecto movimientos_inventario_AAAA-MM-DD.pdf, con fecha de Colombia; el nombre personalizado necesita confirmación. La ficha conserva lectura y descarga después de la baja. Quedan pendientes fotografías, lotes extensos, carga del PDF completo y aceptación integral.

Exportar historial Excel, dentro de la ficha, descarga todos los movimientos de los filtros aplicados, incluso al estar en otra página. Los cambios del formulario sin aplicar no se exportan. Incluye código/nombre del bien, secuencia, fecha UTC, operación, cambio, existencia anterior/posterior, motivo, responsable e identificador del movimiento. Orden descendente de secuencia y once columnas de texto; no contiene fórmulas ni fotografías. Hasta 2000 movimientos: si hay más, se rechaza sin truncar y hay que acotar los filtros. Un resultado vacío produce solo encabezados. La existencia y versión del bien no cambian.

Nombre opcional con confirmación independiente del listado; por defecto movimientos_inventario_AAAA-MM-DD.xlsx, con fecha de Colombia. GET /api/v1/assets/{id}/movements/export exige inventory.export, emisor Gateway y junta firmada; SA/AD/TE conservan lectura incluso tras una baja. Comparte los filtros movement_type, movement_q, movement_from y movement_to; la paginación no limita la descarga. Gateway limita a cinco solicitudes por minuto. Se lee bajo bloqueo del bien, el mismo que serializa los movimientos, y se registra únicamente un evento mínimo inventory.export asociado al bien, sin motivos ni contenido del archivo. La descarga se genera en memoria; cerrar la ficha descarta la respuesta pendiente para evitar descargar una ficha distinta. No requiere migración. El PDF del historial también está disponible; quedan pendientes fotografías, lotes extensos y aceptación integral.

El Historial de movimientos de la ficha permite filtrar por operación (registro inicial, entrada, salida, ajuste o baja), texto del motivo y fechas desde/hasta. Aplicar filtros inicia en la primera página; Limpiar filtros recupera el historial completo. Los días se interpretan en Colombia según la fecha en que se registró el movimiento, incluidos ambos extremos. El fin no puede preceder al inicio. %, _ y ! son texto literal al buscar el motivo.

Fuente de comprobación: docs/INVENTARIO.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

21.4 Carpetas: jerarquía y concurrencia

Referencia operativa: Carpetas

La pantalla Acceso a Carpeta de Configuración presenta en ES/EN la explicación, roles, búsqueda de miembros, selección individual, vigencia, paginación, acciones y resultado de guardado. Chromium verificó con una junta sintética la concesión y revocación por rol y por persona, persistencia tras recargar y ancho de 360 px. La pantalla principal de Carpeta también tiene rótulos ES/EN y permite guardar name (español) y name_en (inglés) al crear o renombrar. La migración aditiva 2026_10_08_000001_add_folder_name_en.php conserva las carpetas antiguas y los clientes que solo envían name; cuando falta name_en, la interfaz inglesa muestra el nombre original. El listado, las migas de pan, el selector de destino y las rutas de búsqueda de archivos usan el nombre inglés cuando existe. Las vistas de archivos privados presentan en ES/EN la carga, el listado, la cuota, las acciones, las vistas previas, el movimiento, el renombrado, la eliminación y los estados vacíos. Los nombres de archivos escritos por personas se muestran tal como se guardaron.

Incrementos de RF-038: creación, navegación, cambio de nombre, movimiento y eliminación de carpetas vacías desde el menú Carpeta. Superadministrador y Administrador gestionan carpetas en su junta. Pueden conceder lectura por rol a Registrador, Tesorero, Auditor y Consultor o individualmente a hasta 20 membresías activas de la junta; sin concesión, ninguno de esos roles accede. La concesión permite navegar, listar, previsualizar y descargar archivos, pero no crear, cargar, renombrar, mover ni eliminar.

La web consume exclusivamente el gateway. El servicio Archivos exige firma interna emitida por el gateway y contexto válido de junta, usuario, sesión y rol. La persistencia está en srd_files.internal_folders, sin consultas a bases de otros servicios. El padre se resuelve dentro de la junta autorizada; los identificadores de otra junta no permiten listar, crear hijos ni renombrar.

La ampliación ES/EN pasó 32 pruebas PHP de Archivos (778 aserciones), compilación web e imágenes Docker. La migración MySQL se aplicó con éxito. Chromium aprobó folder-language.spec.mjs con alta ES/EN, perfil, recarga, rótulos ingleses de archivos y 360 px; también aprobó folders.spec.mjs con auditoría, movimiento, versiones y paginación. El primer intento se había aplazado por memoria; la validación integrada se completó después con servicios mínimos y todos quedaron detenidos al terminar.

El selector de archivos muestra texto ES/EN propio del sistema en lugar del idioma nativo del navegador. El input de tipo file sigue asociado a su etiqueta y se puede enfocar con teclado; la última prueba Chromium verificó ambos idiomas y una captura móvil de viewport. La vista previa y las operaciones continúan autorizándose en el servidor al solicitarlas.

Fuente de comprobación: docs/CARPETAS.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

21.5 Documentos privados y cuotas

Referencia operativa: Documentos privados

Incremento parcial de RF-038/RF-039. Desde Carpeta, Superadministrador y Administrador pueden gestionar archivos privados de su junta, en Inicio o en una carpeta. Cada ubicación pagina 25 archivos. SA/AD pueden delegar la lectura y descarga por rol a Registrador, Tesorero, Auditor y Consultor, o a hasta 20 membresías individuales de la junta activa; la configuración inicia sin delegados. Los lectores no pueden cargar, renombrar, mover ni eliminar, aun llamando a la API directamente. El servidor comprueba la concesión actual y, en el permiso individual, la versión de la membresía en cada descarga y vista previa.

Carpeta también admite imágenes JPEG, PNG y WebP de hasta 5 MiB para SA/AD. Archivos verifica que extensión, tipo y dimensiones correspondan a una imagen real (hasta 20 megapíxeles), analiza el original con ClamAV, lo decodifica y convierte a PNG sin metadatos, vuelve a analizar el resultado y guarda únicamente ese PNG privado. Si cualquiera de esos pasos falla, la carga se rechaza. El tamaño del PNG resultante también debe caber en 5 MiB. El nombre final usa .png; al renombrarlo debe conservar esa extensión. Listado, descarga autenticada, movimiento, eliminación, auditoría, cuota compartida y respaldo siguen el mismo recorrido de archivos privados.

Carpeta admite también WAV PCM de 16 bits, mono o estéreo, de 8 a 48 kHz y hasta 20 MiB. Archivos comprueba cabecera RIFF/WAVE, tamaño total, bloques fmt y data únicos, alineación y tasa de bytes; rechaza bloques adicionales, compresión y datos truncados. Después exige ClamAV y firmas recientes. Guarda los bytes originales aprobados en el volumen privado y comparte

permisos, cuota, versionado, movimiento, borrado, auditoría y respaldo. Escuchar solicita una descarga autenticada bajo demanda, compara sus metadatos con la lista y crea una URL local temporal para el reproductor del navegador; no inicia automáticamente ni publica URL del servidor. La URL local se revoca al cerrar. Otros WAV y notas de voz del chat siguen pendientes.

También se admite un perfil acotado de MP3 MPEG-1 Layer III de hasta 20 MiB: tramas completas consecutivas a 32, 44,1 o 48 kHz, sin bytes adicionales. Acepta etiquetas ID3v2.3/v2.4 sencillas al comienzo e ID3v1 al final; se retiran antes de guardar. Los archivos con etiquetas avanzadas, otros perfiles MPEG o estructuras fuera de esta política se rechazan. ClamAV con firmas recientes analiza tanto el original como el audio sin etiquetas; después FFmpeg decodifica por completo el audio que se guardaría, con plazo y salida acotados. Si cualquiera falla, no se guarda ni se reserva cuota. El tamaño y hash descargables corresponden solo a las tramas guardadas. Permisos, escucha privada, cuota, versión, movimiento, borrado, auditoría y respaldo son los mismos que para WAV. El límite de 15 segundos del decodificador puede rechazar una grabación válida muy larga; otros perfiles MPEG siguen fuera de esta política.

Carpeta admite PDF de hasta 20 MiB para descarga privada. Antes de publicarlo, Archivos comprueba cabecera y cierre, exige ClamAV con firmas recientes y usa Poppler para rechazar cifrado, formularios, JavaScript, archivos incrustados, documentos sin páginas o de más de 1000 páginas; también rechaza declaraciones literales de acciones activas conocidas. El validador tiene límites de tiempo y salida y borra la cuarentena al terminar. Conserva los bytes originales aprobados, con los mismos permisos, cuota, hash, versionado, movimiento, borrado, auditoría y respaldo. No convierte ni sanea el archivo guardado. Ver PDF pide una lectura autenticada nueva para cada página, verifica tamaño y SHA-256, consulta el total (máximo 1000) y renderiza solo la página solicitada mediante Poppler. Devuelve un PNG regenerado sin metadatos de hasta 1200 px por lado y 4 MiB; el PDF original nunca se entrega a ese diálogo. Cada proceso tiene plazo y salida acotados y borra sus archivos temporales. Para usar el archivo original se descarga al lector local. Un PDF válido que use funciones excluidas, o cuya página solicitada no se pueda renderizar dentro de los límites, puede quedar sin vista para esa página aunque su descarga siga disponible.

Fuente de comprobación: docs/DOCUMENTOS-PRIVADOS.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

21.6 Bandeja y entregas

Referencia operativa: Notificaciones

Los avisos nuevos de Calendario conservan title y el title_en opcional que redactó la junta. El trabajo durable, la entrega interna y la bandeja mantienen ambas versiones; la web muestra la correspondiente al idioma persistente de cada usuario. Los avisos anteriores sin title_en conservan el título original. Chat mantiene un título genérico propio del sistema, con su versión inglesa preparada. La migración aditiva de Notificaciones se aplicó en MySQL y las pruebas PHP de entrega y bandeja aprobaron. Chromium confirmó también una invitación real enviada por el planificador de Calendario, la presentación inglesa y el guardado y relectura de una preferencia. La aceptación de todos los tipos de entrega y fallos sigue pendiente.

notifications es una aplicación Laravel independiente con base srd_notifications y credenciales propias. El gateway valida la sesión antes de consultar la bandeja. Cada consulta, lectura o descarte vuelve a verificar la junta y el usuario del contexto firmado. Solo los emisores internos calendar y chat pueden entregar los avisos de su dominio; cada entrega lleva una clave de idempotencia y se

inserta una sola vez. Los cambios de lectura y descarte no eliminan la bitácora: se registran mediante outbox hacia Auditoría.

Chat guarda un trabajo de aviso en la misma transacción que persiste cada mensaje nuevo. Su planificador revisa los trabajos cada minuto, vuelve a verificar en Identidad que el destinatario permanezca activo y entrega un aviso deduplicado. Un fallo temporal se reintenta hasta ocho veces; si el destinatario se desactivó, el trabajo se descarta. El aviso contiene solo la junta, destinatario, conversación y título genérico «Nuevo mensaje»; nunca copia el cuerpo. Al pulsarlo, el gateway y Chat vuelven a comprobar sesión, junta y participación antes de abrir la conversación. Reintentar un envío ya guardado no crea otro trabajo ni otro aviso.

Calendario guarda trabajos de entrega en su propia base, en la misma transacción que crea, modifica o cancela el evento. El planificador entrega avisos de invitación, cambio y cancelación y las anticipaciones elegidas por evento: 24 horas y una hora antes del inicio. Cada anticipación se deduplica por separado y la bandeja indica cuál corresponde. Si el evento se crea después de alguna anticipación pero antes de empezar, ese recordatorio queda listo inmediatamente; dentro de la última hora pueden llegar invitación y ambos recordatorios juntos. El planificador revisa cada minuto; no garantiza entrega en el segundo exacto. Los trabajos pendientes de una fecha antigua se sustituyen al editarla; al cancelar se eliminan los trabajos pendientes de invitación, cambio y recordatorio y se crean avisos de cancelación. Los participantes que rechazan dejan de tener ambos recordatorios pendientes; empezar, cancelar, retirar al participante o cambiar la fecha invalida un trabajo antiguo antes de entregarlo. La entrega se reintenta hasta ocho veces con espera creciente y el receptor deduplica una confirmación repetida. srd:calendar-backfill-reminders prepara ambas anticipaciones de eventos futuros existentes sin duplicarlos; Up.ps1 lo ejecuta al levantar el entorno. Cada evento permite seleccionar ambas anticipaciones, una o ninguna; esa selección se combina con la preferencia personal de recordatorios.

La campana en la web abre una bandeja personal paginada. Muestra avisos sin leer, permite abrir el evento o la conversación, marcar como leído y descartar. La consulta se repite cada 30 segundos mientras la pestaña está visible; el gateway la autentica sin renovar la inactividad de la sesión. Los avisos permanecen dentro de la instalación local: este incremento no envía correos, SMS, push ni datos a terceros.

Fuente de comprobación: docs/NOTIFICACIONES.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

21.7 Chat, paginación y suspensión

Los flujos recientes incluyen adjuntos, borrado diferenciado de mensaje propio para ambas partes o recibido solo en la vista local, imagen con visor, fijados, nota de voz con pausa/vista previa, estados efímeros de escritura/grabación/llamada y eventos persistentes de llamadas finalizadas o perdidas. Deben verificarse los permisos y el comportamiento en varios clientes. WebRTC local no significa conectividad entre redes: configurar/probar TURN y WSS antes de aceptar un piloto.

Referencia operativa: Chat

La lista de Chat consulta la página activa de 25 conversaciones y muestra controles para avanzar y retroceder cuando hay más resultados. El sondeo visible de 15 segundos vuelve a consultar esa misma página. Abrir una conversación desde Contactos o un aviso vuelve al inicio y conserva la selección. Un recorrido Chromium/Compose con 27 conversaciones sintéticas verificó las dos páginas, la permanencia de la segunda después del sondeo y el envío de un mensaje desde ella.

Chat directo e historial pasaron de nuevo. No cambió el esquema ni la API. Quedan la carga concurrente y la aceptación integral del piloto.

El superadministrador puede suspender o reactivar cuentas desde Configuración. Al suspender, Identidad revoca todas sus sesiones en todas las juntas, consume los desafíos de acceso pendientes y encola cada cierre de socket en la misma transacción. Gateway intenta de inmediato los primeros 20 y oculta sus IDs internos; el planificador reintenta los demás o los fallidos hasta recibir confirmación. Reactivar la cuenta no restaura sesiones revocadas. Una prueba Chromium/Compose por WSS confirmó el cierre de un socket directo, el rechazo 401 y la persistencia del rechazo tras reactivar. La cola quedó sin pendientes. La carga concurrente del piloto y TLS de producción siguen pendientes; las secciones inferiores registran etapas anteriores.

Al aceptar los términos de la junta destino, Identidad crea una sesión con ID y token nuevos, conserva el límite absoluto de ocho horas de la sesión anterior y revoca esta última en la misma transacción. Su socket se cierra de inmediato cuando Reverb responde; además, la cola de cierres lo reintenta si falla. Gateway sustituye la credencial privada, renueva su cookie de sesión y no entrega el token al navegador. La web renueva el CSRF tras el cambio. Un recorrido Chromium/Compose por WSS verificó cierre del socket anterior, acceso a la junta nueva y una acción posterior desde Configuración. La suspensión de cuenta y la carga concurrente del piloto siguen pendientes. Las secciones inferiores registran etapas anteriores.

Identidad registra en chat_socket_closures, en la misma transacción que revoca la sesión, cada cierre provocado por logout, Revocar otras sesiones, cambio de membresía, restablecimiento de contraseña o confirmación de nuevo correo. Su planificador intenta cada minuto hasta 100 cierres pendientes mediante la ruta interna firmada de Gateway y marca cada uno como confirmado solo cuando Reverb responde. Si Gateway o Reverb falla, el registro permanece pendiente para otro intento. La migración incorporó 377 sesiones ya revocadas y la cola quedó sin pendientes tras procesarlas. El vencimiento automático mantiene su propio reintento antes de marcar revoked_at.

El cambio de junta conserva el mismo ID de sesión; su cierre inmediato sigue siendo de mejor esfuerzo. Reintentar un cierre antiguo con ese ID podría desconectar el socket de la junta nueva, por lo que no entra en esta cola. La suspensión de cuenta aún no tiene un flujo de cierre forzado. La demora normal del trabajo puede alcanzar el siguiente minuto y aumentar si existe acumulación o fallan dependencias. Las pruebas locales y de navegador descritas en VALIDACION.md cubren el reintento simulado y el cierre real por WSS; no acreditan carga concurrente del piloto. Las descripciones inferiores registran etapas anteriores y sus pendientes en aquel momento.

Fuente de comprobación: docs/CHAT.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

21.8 Supervisión y sondas

Referencia operativa: Supervision

SA/AD reciben además un aviso de entrega de auditoría cuando algún emisor tiene eventos que agotaron sus cuatro intentos. Gateway consulta en paralelo los nueve emisores con contexto firmado de la junta activa y devuelve solo nombre fijo, disponibilidad y conteo; un emisor sin respuesta aparece como estado desconocido, no como cero eventos. El botón Ver auditoría abre la sección donde pueden revisar y programar un reintento individual. La consulta se hace en una pestaña visible cada minuto y al recuperarla, sin renovar la sesión inactiva. El aviso no incluye

acciones, actores ni contenido de los eventos; tampoco envía alertas con SRD cerrado. GET /api/v1/system/audit-deliveries exige SA/AD y tiene límite de diez consultas por minuto.

En la misma pestaña visible, SA/AD también reciben un aviso si hay avisos de Calendario o correos de invitación y seguridad que agotaron sus intentos en la junta activa. El aviso muestra conteos, abre el panel donde se pueden examinar y reintentar individualmente, y desaparece cuando ya no quedan agotados. Si una de las dos consultas falla, la aplicación indica que el estado puede estar incompleto. Estas lecturas se repiten cada minuto y al recuperar la pestaña o la conexión sin renovar la sesión inactiva. Los conteos no muestran destinatarios ni contenido, no comprueban la recepción del correo y no incluyen códigos de acceso o recuperación.

Mientras un SA/AD tiene abierta una pestaña visible de SRD, la aplicación consulta el estado de los nueve planificadores al entrar y cada minuto. Si falta la señal reciente de alguno, muestra un aviso con sus nombres y un acceso a Configuración → Estado de servicios; el aviso desaparece al recuperarse. Si falla la consulta, indica que no pudo comprobar el estado. Al volver a la pestaña o recuperar la conexión, consulta de nuevo. El sondeo no renueva la actividad de la sesión y no se realiza para otros roles. Es un aviso dentro de la aplicación: no envía correo, notificación del sistema ni alertas cuando la pestaña está cerrada. Tampoco acredita el resultado individual de las entregas.

Los nueve planificadores de Compose tienen una comprobación de salud propia. Cada ciclo de Laravel actualiza un marcador local al contenedor y la tarea srd:outbox actualiza otro solo después de procesar su lote. Docker los considera sanos si ambos marcadores tienen como máximo tres minutos. Esto permite detectar que el proceso continúa vivo pero el publicador de auditoría no se ejecuta, por ejemplo a causa de un bloqueo huérfano. Al arrancar, cada planificador limpia los mutex de tareas que quedaron en su contenedor antes de iniciar schedule:work. El bloqueo de srd:outbox vence a los treinta minutos en vez del valor predeterminado de veinticuatro horas; el lote está limitado a cien eventos y cada petición a Auditoría a quince segundos. Al iniciar, dispone de tres minutos para ejecutar el primer ciclo. En Docker Desktop, un planificador detenido aparece como contenedor detenido y uno que permanece activo sin completar estos ciclos pasa a unhealthy. Se puede consultar el estado de todos, incluidos los detenidos, con docker compose ps -a desde la carpeta SRD. Compose muestra el fallo, pero no reinicia automáticamente un contenedor unhealthy ni emite una alerta. Esta comprobación no cambia datos de negocio ni requiere migración; acredita que el ciclo y el publicador llegaron a ejecutarse, no que todos los eventos o entregas externas hayan tenido éxito.

El panel Configuración → Estado de servicios → Planificadores muestra a SA/AD los nueve resultados de esa comprobación: señal reciente del ciclo y del publicador de auditoría. Cada pareja API/planificador comparte solo sus dos marcadores en un volumen local; la API monta ese volumen en modo lectura. Gateway consulta las nueve API en paralelo mediante peticiones internas firmadas, exige sesión y rol de administración antes de responder y devuelve únicamente identificadores fijos y booleanos. La pantalla se actualiza al pulsar Actualizar estado. Si una API no responde, sus dos señales aparecen ausentes; el panel no distingue esa causa de un planificador sin marcadores hasta revisar el estado HTTP del servicio. No se expone Docker ni se abre ningún puerto adicional.

Fuente de comprobación: docs/SUPERVISION.md del repositorio SRD, corte de consulta documental 19 de octubre de 2026.

22. Pruebas mínimas antes de cerrar una incidencia

Checklist de cierre por problema: versión del código/imagen, caso reproducible, dato ficticio, rol, comprobación de autorización, respuesta HTTP/código de dominio, evidencia de regresión dirigida y pruebas colaterales, estado del outbox, firmas antivirus cuando corresponda y decisión responsable. Nunca equiparar una captura aislada con un resultado de aceptación integral.

Categoría	Prueba positiva	Prueba negativa
Autenticación	Sesión válida y MFA	Código incorrecto o sesión revocada
Aislamiento	Leer registros de junta activa	Intentar id de otra junta
Personas	Crear/editar ficha válida	Documento repetido o versión antigua
Carpetas	Crear, renombrar y mover	Mover a descendiente o borrar carpeta con contenido
Documentos	Subir DOCX limpio permitido	Rol sin permiso o archivo fuera de límite
Calendario	Crear evento con invitación	Edición con versión anterior
Tesorería	Ingreso y comprobante	Egreso que excede saldo
Inventario	Movimiento con historial	Operación sobre bien no autorizado
Auditoría	Evento recibido una vez	Reenvío duplicado del mismo id
Chat	Mensaje a integrante autorizado	Acceso a conversación ajena

22.1 Evidencia que debe archivarse

Por cada caso se conserva la fecha, la junta sintética usada, el comando o recorrido, la aserción esperada, el resultado y los archivos de log necesarios. Una captura de pantalla puede ayudar, pero no sustituye un resultado automatizado cuando existe. Las capturas nunca deben exponer cookies, claves, códigos MFA ni datos privados.

23. Referencia de archivos del repositorio

Documento fuente	Uso recomendado
docs/ARQUITECTURA.md	Topología y fronteras entre dominios
docs/PERMISOS.md	Autorización de roles y delegaciones
docs/OUTBOX.md	Estados, reintentos y publicador de auditoría
docs/VALIDACION.md	Resultados de ejecución y limitaciones
docs/TRAZABILIDAD.md	Requisito y estado de implementación
docs/RESPALDOS.md	Copia cifrada y simulacro aislado
docs/ESTADO.md	Deuda técnica y funciones pendientes
contracts/*.openapi.json	Contratos de cada dominio
scripts/Test*.ps1	Rutas concretas de verificación
services/*/database/migrations	Propiedad del esquema y orden de cambios

Estas rutas deben consultarse en el mismo corte de código utilizado en el despliegue. Esta revisión toma como referencia el repositorio empaquetado el 19 de octubre de 2026 y conserva la evidencia del 9 de octubre como historial.